CMMC / CUI DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — CMMC / CUI DLP Pack (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 4

Boundaries (so scope is clear) . . . 5

1. Solution Overview — CMMC / CUI DLP Pack (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 6

The five DLP locations (and what each controls for CUI) . . . 7

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 7

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 8

2. Requirements — CMMC / CUI DLP Pack (Microsoft Purview) 9

2.1 A CUI marking & labeling decision (the prerequisite that makes DLP possible) . . . 9

2.2 Licensing sufficient for CUI DLP — especially Endpoint DLP and label-based conditions . . . 10

2.3 Tenant type confirmed — Commercial vs GCC vs GCC High . . . 10

2.4 CUI-handling scope (enclave) and included/excluded population . . . 10

2.5 Devices onboarded to Purview for Endpoint DLP . . . 11

2.6 CUI marking keyword list / custom SIT source (backs up the label) . . . 11

2.7 A pilot ring, simulation dwell time, and change control (CUI-specific) . . . 11

2.8 An incident/alert triage owner, destination, and evidence retention . . . 12

Global Requirements — Microsoft Purview Solutions 13

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 14

3. Security & Compliance PowerShell + Graph toolchain . . . 14

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 15

3. Implementation Guide — CMMC / CUI DLP Pack (Microsoft Purview) 15

Phase 0 — Connect, confirm tenant, and baseline (Assess) . . . 16

Phase 1 — Confirm the CUI detection layer (label + markings) . . . 16

Phase 2 — Build the CUI DLP policies in SIMULATION (Configure — no user impact) . . . 17
Phase 3 — Measure and tune (drive false positives down) . . . 18
Phase 4 — Enforce in a pilot ring (Pilot) . . . 18
Phase 5 — Expand, enforce, and evidence (Enforce → Operate) . . . 19
Order-of-operations summary . . . 19
5. Testing & Validation — CMMC / CUI DLP Pack (Microsoft Purview) 20
Test A — Detection & enforcement (CUI leaks are blocked) . . . 20
Test B — False-positive rate (adoption & assessment gate) . . . 21
Test C — Incident / alert handling & evidence (the control is operable and auditable) . . . 22
Simulation-first & rollback validation . . . 22
Evidence to capture (for the deliverable record & control narrative) . . . 23
6. Troubleshooting — CMMC / CUI DLP Pack (Microsoft Purview) 23
CUI detection (label & marking) . . . 23
Enforcement / simulation confusion . . . 24
Endpoint DLP . . . 25
GCC High / tenant differences . . . 25
Alerts / incident handling & evidence . . . 25
Connectivity / tooling . . . 26
7. Best Practices — CMMC / CUI DLP Pack (Microsoft Purview) 27
Label first, keywords second . . . 27
Simulate before you enforce — always . . . 27
Scope to the CUI enclave . . . 27
Tune for a low false-positive rate (adoption depends on it) . . . 28
Right-size the user experience . . . 28
Endpoint DLP specifics . . . 28
GCC High & tenant discipline . . . 28
Evidence & operations (this is what an assessor asks for) . . . 28
Stay inside the boundary . . . 29
8. Deliverables Summary — CMMC / CUI DLP Pack (Microsoft Purview) 29
Documentation . . . 29
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 30
Definition of done . . . 31
Appendix A — PowerShell Scripts 33

Executive Summary — CMMC / CUI DLP Pack (Microsoft Purview)

The problem

Organizations holding **Controlled Unclassified Information (CUI)** under a federal contract must show, under **DFARS 252.204-7012**, **NIST SP 800-171**, and **CMMC**, that CUI does not leave the boundary uncontrolled. But CUI is defined by **marking**, not by a magic detector — there is no single built-in "CUI" type — so a data-loss program that ignores marking will both miss real CUI and fire on everything. And the classic failure — switching data-loss controls straight to "block" — floods the help desk with false positives, blocks contract work, and gets turned off within a week.

The solution

Stand up **CUI-tuned Microsoft Purview Data Loss Prevention (DLP)** across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection is **marking-aware**: policies key off the `CUI` **sensitivity label** (the primary, precise signal that follows your marking decision) with a **CUI banner/marking keyword type** as a backstop for marked-but-unlabeled CUI. The defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be blocked with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **pilot ring**, then expanded across the CUI-handling enclave. The result: CUI leaks are blocked without blocking the contract.

What it delivers

- A **marking-aware detection layer** — the `CUI` label as primary signal plus a keyword backstop built from

your **real** CUI markings (never invented).

- **DLP policies across email, cloud, Teams, and endpoint**, scoped to the CUI enclave, each proven in

simulation, tuned, and enforced through policy tips, justification/override, or block/encrypt.

- A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control

people trust and one they ignore.

- An **incident/alert triage workflow with a retained evidence trail** in Activity Explorer — the auditable

record an assessor or contracting officer expects.

- **Five PowerShell tools** (posture assessment, policy config helper, validation-gate checker, match/

false-positive & evidence report, scope helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **CUI leaks blocked** across the channels controlled data actually walks out through — external email, cloud sharing, and USB/print on endpoints.

• **Minimal disruption** — simulation-first plus enclave scoping and tuning means the control catches CUI without a wave of false positives, and any policy reverts to simulation instantly if needed.

• **Operable, auditable, and defensible** — matches raise alerts that are triaged to disposition, with an evidence trail retained to support the control narrative.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and tooled to run in-house.

Boundaries (so scope is clear)

CUI DLP is licensing-/tenant-dependent — **Endpoint DLP and label-based conditions require E5 / E5 Compliance and onboarded devices**, and CUI enclaves are frequently **GCC High**, where availability and portal paths must be **verified** (never assumed). This solution provides the **technical configuration and the evidence**. *Which* data is CUI, *which* categories/markings apply, the **enforced action per condition**, GCC High residency, DFARS incident-reporting obligations, and — critically — **whether a NIST SP 800-171 / CMMC practice is satisfied, the SPRS score, and the assessment outcome** are **compliance, contracts, legal, and certified-assessor (C3PAO) determinations**, captured alongside the delivered evidence.

1. Solution Overview — CMMC / CUI DLP Pack (Microsoft Purview)

What this solution is

Organizations that hold **Controlled Unclassified Information (CUI)** under a federal contract — Covered Defense Information / Controlled Technical Information under **DFARS 252.204-7012**, and the safeguarding expectations of **NIST SP 800-171** and **CMMC** — must be able to show that CUI does not leave the boundary uncontrolled. **Microsoft Purview Data Loss Prevention (DLP)** provides that control: it detects CUI as it moves through **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** and applies an action — audit, warn with a **policy tip**, allow with a **justification**, or **block** — when CUI is about to leave the boundary or reach an unauthorized recipient.

This solution is a repeatable, evidence-driven way to stand up **CUI-tuned DLP** using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party DLP tooling. Its two defining disciplines are **marking-awareness** — DLP keys off the **CUI sensitivity label** and the **CUI banner/portion markings** your organization applies, not a guessed pattern — and **simulation-first**: every policy is built and proven in **SIMULATION mode** (Microsoft's built-in test mode that shows what *would* be blocked, with zero user impact), tuned for a low false-positive rate, and only then enforced.

> ***Scope boundary — CMMC/CUI determinations are deferred.*** *This solution delivers the* ***technical DLP method and the evidence****. *Which* data is CUI, *which* CUI categories apply, *how* CUI must be marked, and *what* the enforced action must be are* ***compliance, contracts, records, and legal determinations****. **CMMC control-satisfaction and assessment determinations — whether a given NIST SP 800-171 / CMMC practice is "met", the SPRS score, and the assessment outcome — are the responsibility of your compliance function and, for certification, a certified third-party assessor (C3PAO).** This pack configures and proves a supporting technical control and produces evidence for it; it does not make the assessment call.*

Why this matters

• **CUI is defined by marking, not by a magic detector.** There is no single built-in "CUI" sensitive

information type. CUI is identified by the **CUI banner marking** (e.g. `CUI`, `CUI//SP-CTI`, `CUI//SP-EXPT`) your organization applies per the **NARA CUI Registry** and 32 CFR Part 2002, and by the **sensitivity label** you attach to it. A DLP program that ignores marking will both miss real CUI and fire on everything.

• **DLP switched straight to enforce is the classic failure** — it blocks legitimate contract work, floods

the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives an assessment and one that was turned off before it.

• **CUI environments are frequently GCC / GCC High.** Feature availability, portal paths, and some SIT/label

capabilities differ between Commercial, GCC, and **GCC High** tenants. This solution **flags "verify your licensing/tenant"** rather than asserting availability — GCC High in particular must be verified.

• The same label + SIT layer that drives CUI DLP also drives **encryption, auto-labeling, and insider

risk** — getting CUI marking right here pays off across the whole safeguarding program.

How it works

1. **The CUI sensitivity label is the primary signal.** A published `CUI` sensitivity label (optionally

with sub-labels per CUI category, e.g. `CUI//SP-CTI`) applies **content markings** (header/footer banner `CUI`) and, where required, **encryption**. DLP conditions then match **"content contains sensitivity label = CUI"** — the most reliable detector because it follows the marking decision a human or auto-labeling policy already made.

1. **Marking/keyword detection backs up the label.** A **custom SIT / keyword dictionary**

(`CUI Banner Marking – Custom SIT – Classification`) detects the literal **CUI banner and portion markings** in body/attachment text, so CUI that is marked-but-not-yet-labeled (or arriving from a partner) is still caught. Category-specific keyword lists (e.g. export-control, CTI terms) refine it. *No marking string is invented — you supply the exact markings your CUI policy uses.*

1. **DLP policies** bind the label + marking conditions to **locations** (Exchange, SharePoint, OneDrive,

Teams, **Devices/Endpoint**) with **conditions** (label present, marking present, recipient is external), **actions** (audit / notify / restrict / block; on endpoint restrict USB/print/cloud-upload/clipboard), and **user experience** (policy tips, allow-with-justification).

1. **Simulation mode** runs each policy against live traffic and records what *would* have matched — with no

enforcement — so the true hit volume and false positives are known **before** anything is blocked.

1. **Tuning** reduces false positives (label-based conditions, confidence, instance counts, exceptions),

measured against the simulation results.

1. **Enforcement + evidence** turns the tuned policy on for a pilot ring then expands, while **DLP alerts**

and **Activity Explorer** produce the **evidence trail** an assessor or contracting officer expects.

The five DLP locations (and what each controls for CUI)

- **Exchange (email):** outbound mail carrying CUI to external/unauthorized recipients — block or encrypt.
- **SharePoint & OneDrive:** CUI documents at rest and when shared — block external sharing on match.
- **Teams chat & channel messages:** CUI pasted or shared in messages.
- **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy CUI to USB, copy to

network share, print, upload to unallowed cloud apps/browser, copy to clipboard. **Requires onboarding and the right licensing.**

- **On-premises / cloud apps (Defender for Cloud Apps):** additional locations that may be available

depending on licensing/tenant — **verify availability (especially GCC High).**

The simulate→enforce journey (the core discipline)

> *Confirm the **CUI label + markings** (compliance decision) → build each DLP policy keyed on **label = CUI** and **CUI markings** in **SIMULATION** (no user impact) → measure hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** → re-simulate until false positives are acceptable → enable with **policy tips + allow-override** in a **pilot ring** → validate → expand to **enforce (block/encrypt)** across the CUI-handling population → operate (triage alerts, retain evidence, re-tune).*

What you can control

- Which **CUI sensitivity label(s)** and which **CUI markings/keywords** each policy detects.
- Which **locations** each policy covers and which users/sites/groups are **included or excluded** (the

CUI-handling enclave vs the rest of the tenant).

- The **action** per condition (audit → tip → justify → block/encrypt) — set per the CUI safeguarding

determination.

- Whether users get **policy tips**, can **override** with justification, and the notice wording.
- The **pilot ring** enforced first and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

• **CUI marking is a prerequisite, not an output.** DLP is only as good as the marking/labeling program

feeding it — if CUI is not marked or labeled, a marking-keyed policy cannot see it. This pack assumes (and its Requirements name) a CUI labeling decision.

• **Endpoint DLP requires onboarded devices and the appropriate licensing** (verify your plan — endpoint DLP

and several advanced classifiers are gated behind **E5 / E5 Compliance**). A Devices-location policy is inert until onboarding is complete.

• **GCC High and preview features must be verified** — availability and portal paths differ; this solution

flags rather than asserts.

• DLP inspects **content it can classify**; strongly-encrypted or unrecognized formats, or content below the

match threshold, will not match. DLP is one NIST SP 800-171 / CMMC supporting control among many, not a guarantee of compliance.

• **The enforced action, the CUI categories in scope, and CMMC assessment outcomes are compliance / legal /

C3PAO decisions**, not technical defaults — this solution configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
CUI sensitivity label (parent)	`CUI`
CUI sub-label (per category, example)	`CUI//SP-CTI`, `CUI//SP-EXPT`
CUI marking keyword SIT	`CUI Banner Marking – Custom SIT – Classification`
Email DLP policy (simulation)	`DLP – CUI Email – Simulation`
Cloud DLP policy (simulation)	`DLP – CUI SPO+OneDrive+Teams – Simulation`
Endpoint DLP policy (simulation)	`DLP – CUI Endpoint – Simulation`
Enforced pilot policy	`DLP – CUI All Locations – Enforce Pilot`
Pilot user ring	`CUI DLP Pilot Ring – Stage1`
Policy-tip / override text	`CUI Notice – Standard – AllPolicies`
Incident/alert workflow	`CUI DLP Alerts – Triage – Operations`

The standard deployment model

> ***Assess** current CUI exposure, marking/label state, and licensing/tenant (incl. GCC High) → **Design** the label + marking detection and the policies/user experience → **Configure** policies **in simulation** → **Pilot** (simulate → tune → enforce to a ring) → **Validate** against pass/fail gates (CUI leaks blocked, false-positive rate low, incidents handled + evidenced) → **Expand** to the full CUI-handling population and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback. Regulatory/records/legal and **CMMC assessment determinations are deferred**.*

2. Requirements — CMMC / CUI DLP Pack (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing CUI-tuned Purview DLP for CMMC / DFARS / NIST SP 800-171 alignment. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

> ***Determination boundary.** Whether a NIST SP 800-171 / CMMC practice is **satisfied**, the SPRS score, and the assessment outcome are decided by your **compliance function and a C3PAO** — not by this pack. *Which* data is CUI, *which* CUI categories/markings apply, and the *enforced action* are compliance / contracts / legal determinations. This pack provides the technical control and evidence.*

2.1 A CUI marking & labeling decision (the prerequisite that makes DLP possible)

• **Description:** A documented **CUI marking and sensitivity-labeling decision** from your compliance/

contracts function: the **CUI banner and portion markings** you use (per the **NARA CUI Registry** / 32 CFR Part 2002 — e.g. `CUI`, `CUI//SP-CTI`, `CUI//SP-EXPT`), and the **Purview sensitivity label(s)** (`CUI`, with sub-labels per category if used) that carry those markings. DLP in this solution keys off the **label** and the **markings**.

• **Why required:** There is **no built-in "CUI" detector**. DLP can only act on CUI that is **marked or

labeled**; the marking/label decision is the input the whole program depends on.

• **How to verify:** Confirm the marking scheme with compliance; in **Purview portal → Information protection

→ Sensitivity labels**, confirm the `CUI` label (and any sub-labels) exist and are** published** to the CUI-handling users.

• **How to implement if missing:** Have compliance define the marking scheme and stand up the `CUI`

sensitivity label(s) with the correct content marking (and encryption where required) **before** building marking-keyed DLP. *Which markings/categories apply is a compliance determination, not a technical one.*

2.2 Licensing sufficient for CUI DLP — especially Endpoint DLP and label-based conditions

• **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** and **built-in SITs** is broadly available,

but **Endpoint DLP**, **sensitivity-label-based DLP conditions**, **custom classifiers**, and **Exact Data Match** are typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some capabilities are in **preview**). Extends GR-#1.

• **Why required:** A policy that scopes the Devices location or matches on a **sensitivity label** requires

the plan that includes those capabilities; otherwise the policy will not function.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the

Purview portal → **Data Loss Prevention** confirm the **Devices** location and the **"content contains sensitivity label"** condition are available. **Flag "verify your licensing/tenant."**

• **How to implement if missing:** Acquire/assign E5 / E5 Compliance before building endpoint or label-based

policies; scope the initial rollout to features your plan covers.

2.3 Tenant type confirmed — Commercial vs GCC vs GCC High

• **Description:** The **cloud environment** the CUI enclave lives in — **Commercial, GCC, or GCC High** —

confirmed, because feature availability, portal URLs, and some SIT/label behaviors **differ** between them. Many CUI/CDI (and export-controlled) workloads run in **GCC High**.

• **Why required:** Portal paths and capability availability this solution cites are from Microsoft's public

docs for Commercial/GCC; **GCC High can differ** and must be verified rather than assumed. *Whether CUI must reside in GCC High (e.g. for ITAR/export-controlled categories) is a compliance/contracts determination.*

• **How to verify:** Confirm the tenant type with your admins; confirm the correct Purview portal endpoint

for that environment and that the features you plan to use are present there.

• **How to implement if missing:** Determine the tenant type before authoring; treat every portal path/

capability as **"verify in your (GCC High) tenant"** and adjust where Microsoft's GCC High docs differ.

2.4 CUI-handling scope (enclave) and included/excluded population

• **Description:** The **users, groups, sites, and devices that handle CUI** — the CUI enclave — identified

as the DLP **included** scope, with the rest of the tenant **excluded** (or covered by a lighter policy). Extends GR-#4.

• **Why required:** CUI DLP should focus enforcement where CUI actually is; scoping to the enclave reduces

false positives and blast radius, and keeps the control defensible.

- **How to verify:** Confirm the enclave membership (users/groups/sites/devices) with the CUI program owner;

confirm the groups exist in the tenant to scope policies against.

- **How to implement if missing:** Define the enclave and the security groups/site list before scoping

policies; the delivered scope helper reports and (with `-Commit`) sets the included/excluded scope.

2.5 Devices onboarded to Purview for Endpoint DLP

- **Description:** Endpoint DLP monitors activities on **onboarded Windows 10/11 and macOS devices**.

Onboarding is done in **Purview portal** → **Settings** → **Device onboarding** (or via Intune / script / Group Policy) and is **shared with Microsoft Defender for Endpoint onboarding**.

- **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not

onboarded and reporting — and CUI often walks out via USB/print on endpoints.

- **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded devices;

confirm the CUI-handling devices appear and are reporting.

- **How to implement if missing:** Onboard devices via the Purview package, Intune, or Group Policy; confirm

the minimum OS build and required agent/AV state per Microsoft docs before scoping endpoint policies.

2.6 CUI marking keyword list / custom SIT source (backs up the label)

- **Description:** The exact **CUI banner and portion-marking strings** (and any category keyword lists — CTI,

export-control, etc.) to build the `CUI Banner Marking – Custom SIT – Classification` keyword SIT that catches marked-but-unlabeled CUI. Supplied by compliance from your marking policy.

- **Why required:** The label is the primary signal but does not cover CUI that arrives marked-but-unlabeled

(e.g. from a partner) or is authored before labeling. The marking SIT is the backstop — and it must use **your real markings**, not invented strings.

- **How to verify:** Confirm the marking strings with compliance; test the resulting custom SIT in the SIT

wizard's **Test** step against known-marked sample text.

- **How to implement if missing:** Obtain the marking list from compliance and build the keyword SIT; if a

category is conceptual (not string-based), evaluate a trainable classifier (verify availability/plan).

2.7 A pilot ring, simulation dwell time, and change control (CUI-specific)

• **Description:** A named **CUI pilot ring** (`CUI DLP Pilot Ring – Stage1`), an agreed **simulation dwell

time **(long enough to capture representative CUI traffic), and the** change-control window** for moving simulation → enforce. Extends GR-#6.

• **Why required:** CUI DLP is high-impact and touches contract-critical work; enforcing without a simulation

baseline and a limited ring is how the control breaks the business and gets disabled. Simulation-first is mandated by the house model.

• **How to verify:** Confirm the ring membership, that **simulation mode** is selected on each new policy,

and the approval path to enforce.

• **How to implement if missing:** Define the ring and dwell time and agree change control before enabling

any enforcement action.

2.8 An incident/alert triage owner, destination, and evidence retention

• **Description:** A named owner (or queue) for **CUI DLP alerts** (`CUI DLP Alerts – Triage – Operations`)

in **Purview** → **Data loss prevention** → **Alerts**, where events are reviewed (**Activity Explorer**), where they are forwarded (SIEM / Microsoft Sentinel, if used), and how the **evidence is retained** for assessment/audit.

• **Why required:** A CUI match with no triage is not a control — and CMMC/DFARS expect an **auditable

evidence trail** of incident handling. Someone must own triage, severity, response, and evidence retention.

• **How to verify:** Confirm the triage owner/queue, the severity scheme, any SIEM forwarding, and the

evidence-retention location/period.

• **How to implement if missing:** Assign the owner, define severity/response and retention, and (optionally)

wire SIEM forwarding before enforcement generates real alerts. *Incident-reporting obligations under DFARS are a compliance/legal determination.*

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	CUI marking & sensitivity-label decision	DLP has a marking/label to key off

#	Requirement	Gate
2.2	Licensing (E5 / E5 Compliance; label-based + endpoint)	Endpoint & label conditions available
2.3	Tenant type confirmed (Commercial/GCC/**GCC High**)	Paths/features verified, not assumed
2.4	CUI enclave scope (included/excluded)	Enforcement focused on CUI population
2.5	Devices onboarded to Purview	Endpoint location functional
2.6	CUI marking keyword SIT source	Marked-but-unlabeled CUI still caught
2.7	Pilot ring + simulation dwell + change control	Simulate-first enforced
2.8	Alert triage owner + destination + evidence retention	Matches acted on and evidenced

> ***Deferred to compliance / contracts / legal / C3PAO:*** *which data is CUI, which categories/markings apply, the enforced action per condition, DFARS incident-reporting obligations, GCC High residency requirements, and* ***all CMMC / NIST SP 800-171 control-satisfaction and assessment determinations****. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.
- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.
- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.
- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.
- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — CMMC / CUI DLP Pack (Microsoft Purview)

This is the exact, ordered procedure to implement **CUI-tuned Purview DLP** across **email, cloud, Teams, and endpoint** — every policy keyed on the **CUI sensitivity label** and **CUI markings**, built in **SIMULATION** first, tuned, then enforced to a ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths (and any GCC High differences) are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. They are **read-only or** `-WhatIf` **by default**; writes require an explicit* `-Commit` *switch, and the config helper never leaves a policy in enforce. No credentials are stored in code.*

> ***Determinations deferred.*** **Which* data is CUI, *which* markings/categories apply, the *enforced action* per condition, and* ***whether a CMMC / NIST SP 800-171 practice is satisfied*** *are compliance / contracts / legal / C3PAO decisions. This guide configures and proves a supporting control and produces evidence; capture those determinations before Phase 3.*

Phase 0 — Connect, confirm tenant, and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

GCC High: use the environment-specific connection parameters per Microsoft's GCC High docs and the correct portal endpoint — **verify in your tenant**.

1. **Confirm the CUI label exists and is published** (Req 2.1) and **run the posture assessment** (delivered

script #1, read-only):

```
.\DLPCMMC-Discovery.ps1 -CsvPath .\DLPCMMC-Posture.csv
```

It reports existing DLP policies and their mode, whether a `CUI` **sensitivity label** and marking SIT are present, and licensing/endpoint readiness signals.

1. **Confirm licensing, tenant type, and endpoint readiness** (Req 2.2/2.3/2.5): E5/E5-Compliance where

endpoint or label-based conditions are needed, the tenant environment (Commercial/GCC/**GCC High**), and that CUI-handling devices are **onboarded**.

Pass/fail gate: you have a written baseline (existing policies + modes), confirmation the `CUI` label is published, a confirmed tenant type, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Confirm the CUI detection layer (label + markings)

Do **not** invent CUI markings or a CUI SIT. Use the **label** as the primary signal and build the **marking keyword SIT** only from the strings compliance supplies.

1. **Confirm the CUI sensitivity label** (Req 2.1). In **Purview portal → Information protection →

Sensitivity labels**, confirm the** `CUI` **label (and any sub-labels, e.g.** `CUI//SP-CTI`**,** `CUI//SP-EXPT`**) exists, applies the** content marking **(header/footer banner** `CUI`**), applies** encryption **where the CUI category requires it, and is** published** to the CUI-handling users. *If the label does not exist, that is a labeling-program task (a separate solution) — DLP cannot proceed without it.*

1. **Build the CUI marking keyword SIT** (Req 2.6). In **Purview portal → Data classification → Classifiers →

Sensitive info types → Create sensitive info type**, create** `CUI Banner Marking – Custom SIT – Classification` **using the** exact banner/portion-marking strings **compliance supplied (as a keyword list / regex with proximity). Test it in the wizard's** Test** step against known-marked sample text. Add

category keyword lists (CTI, export-control) only if supplied.

1. **Decide the primary DLP condition.** Prefer **"content contains sensitivity label =** `CUI`**"** (most

reliable — follows the marking decision) with the **marking SIT** as a secondary/OR condition to catch marked-but-unlabeled CUI. *Which conditions and thresholds legally suffice is a compliance determination.*

Pass/fail gate: the `CUI` label is confirmed published, and the marking SIT is created and tested to match your real CUI markings without matching ordinary text. **Rollback:** delete the unused custom SIT (it has no effect until referenced by a policy). Do **not** delete the label (managed by the labeling program).

Phase 2 — Build the CUI DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group**, each in **simulation mode**, each keyed on **label = CUI** (and the marking SIT). Simulation evaluates against real traffic and records what *would* match, with **no** enforcement.

1. **Email DLP policy —** `DLP – CUI Email – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** (custom) → **Locations: Exchange email only** → rule: condition *Content contains → Sensitivity labels → `CUI`* (OR *Content contains → Sensitive info types → CUI Banner Marking SIT*), plus *Recipient is external* → action *Restrict access or encrypt* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Scope to the **CUI enclave** (Req 2.4). Finish.

1. **Cloud DLP policy —** `DLP – CUI SPO+OneDrive+Teams – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** (scope to the CUI sites/enclave) → same label/marking conditions → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint DLP policy —** `DLP – CUI Endpoint – Simulation` (requires onboarded devices + licensing).

Same flow → **Locations: Devices** (enclave devices) → same label/marking conditions → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard* → **simulation mode**. If the Devices location is not selectable, revisit licensing/onboarding (Req 2.2/2.5).

1. **Set the user experience** consistently: define `CUI Notice – Standard – AllPolicies` policy-tip text

(plain-language: this content is marked CUI; sending it externally is restricted) and enable **allow override with justification** where compliance permits.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\DLPCMMC-Config.ps1 -PolicyName 'DLP - CUI Email - Simulation' -Locations Exchange `
    -SensitivityLabel 'CUI' -MarkingSit 'CUI Banner Marking - Custom SIT - Classification' -WhatIf
```

Run with `-Commit` only to apply an intended change; the script creates in **simulation** and never leaves a policy in enforce.

Pass/fail gate: all three policies exist and are confirmed in **simulation** (script #1/#3 report a `Test*` mode), scoped to the CUI enclave and keyed on the `CUI` label + marking SIT. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.7) to capture representative CUI traffic.

1. **Review what matched. Purview** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the label/SIT, and the confidence. Export with the reporting script:

```
.\DLPCMMC-Report.ps1 -Days 14 -CsvPath .\DLPCMMC-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the drivers (e.g. the marking

SIT firing on a document that merely *quotes* the word "CUI" in guidance text).

1. **Tune** to reduce false positives without losing true positives:

• **Prefer the label condition** — label-based matching is far more precise than keyword marking.

• Add **proximity/keyword context** to the marking SIT so a stray "CUI" mention doesn't fire.

• Add **exceptions** (e.g. a known compliance-training library that discusses CUI) where justified.

• Tighten the **external-recipient / sharing** condition so internal enclave movement isn't flagged.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the

validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true positives (real marked/labeled CUI) still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Set `CUI DLP Pilot Ring – Stage1` (users) and pilot enclave devices as the

included scope on each policy (all others excluded for now) — the scope helper reports/sets this:

```
.\DLPCMMC-Set-Scope.ps1 -PolicyName 'DLP - CUI Email - Simulation' -IncludeGroup 'CUI DLP Pilot Ring -
```

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** rather than hard block, so the pilot can report false negatives/positives while retaining a business escape hatch (unless compliance mandates immediate block/encrypt for a category).

1. **Confirm enforcement is live** for the ring only (script #1/#3 report mode `Enable` and the scoped

identities). Confirm ring users now see the `CUI Notice – Standard – AllPolicies` tip on a test match with fake CUI-marked content.

1. **Handle incidents + capture evidence.** Wire `CUI DLP Alerts – Triage – Operations`: assign the alert

owner/queue (Req 2.8), set severities, retain evidence, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow and the evidence trail.

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured), CUI matches raise alerts, and the triage workflow produces a **dispositioned, evidenced** incident. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand, enforce, and evidence (Enforce → Operate)

1. **Expand scope** from the ring to the full **CUI-handling population/enclave** once the pilot gate

passes, keeping documented exclusions.

1. **Escalate the action** per compliance's determination — e.g. move CUI-to-external from *tip + override*

to **block/encrypt** — one condition/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides, retain the **evidence trail** (alerts, Activity Explorer exports) for assessment/ audit, and re-tune as data and behavior change.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence — this is what supports the CMMC/DFARS/NIST SP 800-171 control narrative (satisfaction determination remains with compliance/C3PAO).

Pass/fail gate: enforcement live across the CUI population with the compliance-mandated action per condition; false-positive rate steady/low; alerts triaged and **evidenced** on cadence; overrides reviewed. **Rollback:** any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, confirm label/tenant/licensing, baseline	Posture CSV	Baseline + `CUI` label + readiness confirmed	n/a (read-only)
1 Detection	Confirm CUI label, build marking SIT	Marking SIT	Label published + SIT tested	Delete unused SIT
2 Configure	Build 3 policies keyed on label+marking in **simulation**	Email/Cloud/Endpoint sim policies	All in simulation, enclave-scoped	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold	Revert tuning change

Phase	Do	Artifact(s)	Gate	Rollback
4 Pilot	Enforce to ring, wire alerts + evidence	Pilot ring, alert triage	Ring enforced, incident evidenced	Back to simulation
5 Expand	Broaden to CUI population, escalate to block/encrypt, evidence	Enforced policies	Full-scope enforce, low FP, evidenced	Simulation / disable

5. Testing & Validation — CMMC / CUI DLP Pack (Microsoft Purview)

Validate the CUI DLP implementation against explicit **pass/fail gates**. The three headline gates are: **(A) CUI leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled and evidenced**. Run every test with **non-real, clearly-fake sample content** — a test document **marked** `CUI` and/or carrying the `CUI` sensitivity label, containing **no real CUI/CDI** — never real controlled data. Record the evidence; it supports the control narrative (the CMMC/NIST SP 800-171 **satisfaction determination stays with compliance/C3PAO**).

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the* `CUI DLP Pilot Ring – Stage1`*. Endpoint tests require an **onboarded** device (Req 2.5). On **GCC High**, confirm each step against your tenant's portal.*

Test A — Detection & enforcement (CUI leaks are blocked)

#	Test	Steps	Pass condition
A1	Labeled-CUI email blocked	From a ring user, apply the `CUI` label to a fake test file and email it to an **external** recipient.	Message is blocked/encrypted per the enforced action; sender sees the CUI policy tip; a DLP alert is raised.
A2	Marked-but-unlabeled CUI email	Send an email whose body/attachment contains the **CUI banner marking** text (matched by the marking SIT) to an external recipient.	Matched by the marking SIT condition; enforced action applied; alert raised — confirms the marking backstop works.
A3	SharePoint/OneDrive external share blocked	As a ring user, upload a `CUI`-labeled fake file and attempt to share it **externally**.	External sharing is blocked/restricted on match; event appears in Activity Explorer.

#	Test	Steps	Pass condition
A4	Teams message match	Paste fake **CUI-marked** content into a Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.
A5	Endpoint — USB / print / cloud upload	On an onboarded ring device, copy a `CUI`-labeled fake file to **removable media**, **print** it, and **upload** it to an unallowed cloud app/browser.	Each activity is audited/blocked per policy; endpoint DLP events appear in Activity Explorer.
A6	Internal-movement / below-threshold negative	Move the same CUI file **internally within the enclave**, and send unmarked/unlabeled content.	Internal enclave movement and non-CUI content are correctly **not** blocked — confirms scoping/conditions hold.

Gate A (pass): A1–A5 each produce the enforced action and a logged event; A6 correctly does not fire.

Test B — False-positive rate (adoption & assessment gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`DLPCMMC-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; label-keyed matching should be very precise, so target a low absolute FP count the triage team can absorb).
B2	"CUI mention" negative	Run legitimate content that merely **mentions** the word "CUI" (e.g. a compliance-training doc) but is not itself CUI.	Not matched — confirms the marking SIT uses proximity/context and the label condition carries the weight.
B3	Post-tuning re-measure	After each tuning change (label-first, proximity, exceptions, recipient scope), re-simulate and re-measure.	FP rate trends **down** while true positives (Test A) still fire.

#	Test	Steps	Pass condition
B4	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true positives intact.

Test C — Incident / alert handling & evidence (the control is operable and auditable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A5).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `CUI DLP Alerts – Triage – Operations` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Activity Explorer evidence trail	Locate the same event in **Data classification** → **Activity explorer** and **export** it.	Full evidence trail present (user, location, label/SIT, action) and retained per Req 2.8 for assessment/audit.
C4	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.8).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner, and the **retained evidence trail** (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `CUI DLP Pilot Ring – Stage1` experience no blocking during pilot.

#	Test	Pass condition
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked CUI action now only simulates).
S3	Scripts are safe-by-default	`DLPCMMC-Config.ps1` / `DLPCMMC-Set-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); discovery/validate/report scripts are read-only.

Evidence to capture (for the deliverable record & control narrative)

• Baseline posture CSV (Phase 0), the `CUI` label confirmation, and the marking-SIT test result.

• Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).

• Screenshots/log of Test A enforcement actions (labeled CUI **and** marked-but-unlabeled) and the raised alerts (Gate A/C).

• The dispositioned, **retained** incident from Test C2/C3 and, if used, the SIEM forward (C4).

• Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

> ***Determination boundary.*** *These tests prove the **control works** and produce the **evidence**. Whether that evidence **satisfies** a given NIST SP 800-171 / CMMC practice, the SPRS score, the acceptable FP threshold, and the enforced action per CUI category are **compliance / contracts / legal / C3PAO** sign-offs, captured alongside the evidence above.*

6. Troubleshooting — CMMC / CUI DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing CUI DLP across email, cloud, Teams, and endpoint. Most problems are one of: a policy not matching CUI, the CUI label/marking not detected, the marking keyword over-firing, the endpoint location unavailable, GCC High path differences, or matches that raise no alert.

CUI detection (label & marking)

A CUI DLP policy matches nothing even though the file is clearly marked/labeled CUI.

• Confirm the policy is **enabled and in a mode that evaluates** — a *disabled* policy does nothing; a

simulation policy evaluates and logs but does not block. Check with `DLPCMMC-Discovery.ps1` (Mode column) or `DLPCMMC-Validate.ps1`.

- Confirm the rule actually references the `CUI` **sensitivity label** and/or the marking SIT — run

`DLPCMMC-Validate.ps1` (the `CUISignalOk` column). A policy with no CUI condition matches nothing relevant.

- **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (longer for

some locations)** to take effect. Wait before concluding it's broken.

- Confirm the **location scope** includes where you're testing and the test identity isn't in an

exclusion (the enclave scope may exclude your test user).

The `CUI` sensitivity label condition isn't available or doesn't match.

- **Label must be published** to the user who applies it (Req 2.1) — confirm in **Purview → Information

protection → Sensitivity labels → label policies**. An unpublished label can't be applied, so DLP never sees it. `DLPCMMC-Discovery.ps1` reports label presence.

- **Label-based DLP conditions are licensing-gated** — confirm the *"content contains sensitivity label"*

condition is available for your plan/tenant (Req 2.2). On **GCC High**, verify availability specifically.

- Content must actually **carry** the label — a file that is marked in text but not labeled won't match the

label condition (that's what the marking SIT backstop is for; test A2 in Testing).

The CUI marking keyword SIT never matches.

- Test the SIT's **keywords/regex + proximity** in the SIT wizard's **Test** step with known CUI-marked

text. A too-strict pattern, wrong **character proximity**, or a required keyword that isn't present will suppress all matches. Loosen and re-test incrementally.

- Confirm you built it from the **exact markings** compliance supplied (Req 2.6) — an invented or

approximate banner string won't match your real documents.

The marking SIT fires on documents that merely mention "CUI".

- This is the classic over-fire. **Prefer the label condition** as primary and demote the marking SIT to a

backstop; add **proximity/context keywords** so a stray "CUI" mention doesn't trigger; add a targeted **exception** for known discussion libraries (e.g. compliance training). Re-simulate after each change.

Enforcement / simulation confusion

Matches appear in simulation but nothing is blocked.

- That is **correct** — simulation logs what *would* happen without enforcing. To block, move the policy to

enforce for the pilot ring (Implementation Phase 4). If you expected blocking, you're still in simulation.

Endpoint DLP

The Devices/Endpoint location isn't available when creating a policy.

• **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — verify in the admin

center; `DLPCMMC-Discovery.ps1` reports the endpoint-policy signal.

• **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview → Settings →

Device onboarding**. No onboarded devices → the location does nothing even if selectable.

Endpoint policy is enforced but CUI activities (USB/print/upload) aren't caught.

• Confirm the specific **device is onboarded and reporting** (portal device list), meets the **minimum OS

build**, and any required agent/AV prerequisites per Microsoft docs are met.

• Confirm the **activity is in scope** of the rule (e.g. "copy to USB" enabled) and the app/browser or

network path isn't on an **allowed/exception** list.

• Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

GCC High / tenant differences

A documented portal path or capability isn't where the guide says.

• **Confirm the tenant type** (Commercial / GCC / **GCC High**) (Req 2.3). GCC High uses different portal

endpoints and some features/preview capabilities differ or are absent — **verify against Microsoft's GCC High documentation** for your environment. The guides flag rather than assert; treat every path as "verify in your tenant."

Alerts / incident handling & evidence

CUI matches occur but no alert appears / no one is notified.

• Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss

prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.

• Confirm **unified audit logging is enabled** in the tenant — the report script and Activity Explorer rely

on it.

• Confirm the **triage owner/queue** (`CUI DLP Alerts – Triage – Operations`) exists and, if forwarding to

SIEM/Sentinel, that the connector is healthy (Req 2.8).

`DLPCMMC-Report.ps1` **returns no matches.**

• **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.

• Freshly created policies need **dwell time** — there may simply be no matches yet.

• Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable **admin. On** GCC High**, use the environment-specific connection parameters.

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data

Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. The config

helper never leaves a policy in **enforce**, and the scope helper never changes **mode** — so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
Policy matches no CUI	Mode (disabled/sim), rule references `CUI` label/SIT (`DLPCMMC-Validate`), propagation time, scope/exclusion
Label condition unavailable/no match	Label published? licensing for label-based DLP? content actually labeled? (GCC High: verify)
Marking SIT never fires	Test keywords+proximity in the SIT wizard; built from real markings?
Marking SIT over-fires on "CUI" mentions	Label-first, add proximity/context, add exception, re-simulate
Nothing blocked	Still in **simulation** — that's expected; enforce the ring to block
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
Portal path not as documented	Confirm tenant type (GCC High differs) — verify against Microsoft docs
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Report returns nothing	Audit latency/dwell time, audit logging on, role

Symptom	First check
Cmdlet/connect fails	Module updated, modern auth (GCC High params), correct DLP role

7. Best Practices — CMMC / CUI DLP Pack (Microsoft Purview)

Field-tested practices for running CUI-tuned Purview DLP so the control stays trusted, effective, low-noise, and **defensible in an assessment**. These complement the Implementation and Testing guides.

Label first, keywords second

- **Key policies on the `CUI` sensitivity label** as the primary condition — it follows the marking decision

a human or auto-labeling policy already made, and is far more precise than string matching. Use the **marking keyword SIT** as the *backstop* for marked-but-unlabeled CUI, not the primary detector.

- **Never invent CUI markings.** Build the marking SIT only from the exact banner/portion strings compliance

supplies (NARA CUI Registry / your marking policy). Add proximity/context so a stray "CUI" mention in guidance text doesn't fire.

- Getting the label right feeds the whole safeguarding program (encryption, auto-labeling, insider risk) —

invest there, not in ever-more-complex DLP regex.

Simulate before you enforce — always

- **Never** switch a new or materially changed CUI DLP policy straight to enforce. Run it in **simulation**

first, long enough to capture representative CUI traffic (Req 2.7), and read the results before enabling.

- Use **simulation with policy tips** on the pilot ring when you want end-user feedback before hard block.
- Treat **simulation mode as your permanent safety switch**: any enforced policy returns to simulation in one

setting, instantly removing enforcement with no data change — this is your rollback.

Scope to the CUI enclave

- Focus enforcement on the **users, sites, and devices that actually handle CUI** (Req 2.4). Enclave scoping

cuts false positives, shrinks blast radius, and keeps the control narrative clean for an assessor.

- Add a condition for **external recipient / external sharing** so internal enclave movement of CUI isn't

flagged as a leak — the risk is CUI *leaving* the boundary.

Tune for a low false-positive rate (adoption depends on it)

- Label-keyed matching should already be precise; most false positives come from the **marking keyword SIT**

over-firing — fix it with proximity, context keywords, and targeted exceptions (e.g. a CUI-training library), not by loosening the label condition.

- Every false positive that reaches a user erodes trust in **every** policy tip. Budget for a tuning cycle,

not a one-time build.

Right-size the user experience

- Show **clear, actionable policy tips** in plain language — tell the user the content is **marked CUI** and

what they may/may not do, not a compliance error code. Reuse one standard notice (`CUI Notice – Standard – AllPolicies`).

- Prefer **allow-with-justification / override** over hard block where legitimate contract exceptions exist,

then **review the overrides** — routine overriding means the policy is mis-scoped. Reserve **hard block/ encrypt** for the categories where compliance requires it.

Endpoint DLP specifics

- **Onboarding is the gate.** A Devices policy is inert until the device is onboarded (shared with Defender

for Endpoint) and reporting — verify onboarding before blaming the policy.

- Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload of CUI before restricting, so you

see real usage and avoid blocking legitimate contract workflows.

- Mind **allowed vs unallowed apps/browsers and network exceptions** so sanctioned tools aren't caught

alongside exfiltration paths.

GCC High & tenant discipline

- **Confirm the tenant type** (Commercial / GCC / **GCC High**) and **verify every portal path and

capability** against that environment's Microsoft docs — GCC High differs and preview features may not be present. Flag, don't assume.

- Whether CUI (especially export-controlled categories) **must reside in GCC High** is a compliance/contracts

determination — not a technical default.

Evidence & operations (this is what an assessor asks for)

- Give CUI DLP **alerts an owner and an SLA** (Req 2.8). Match volume without triage is not a control.

• **Retain the evidence trail** — alert dispositions, Activity Explorer exports, the simulate→enforce change

log, and compliance sign-offs — so the control can be *shown*, not just claimed.

• Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as data and behavior drift.

• Enforce **least-privilege roles** and, where possible, **separate policy authors from alert triagers**.

Stay inside the boundary

• DLP is **one supporting control**, not a compliance guarantee — combine it with the CUI **sensitivity label + encryption**, access control, and insider-risk where the risk warrants.

• The **enforced action, the CUI categories/markings in scope, GCC High residency, DFARS incident-reporting,

and all CMMC / NIST SP 800-171 satisfaction and assessment determinations **are** compliance / contracts / legal / C3PAO** decisions — you provide the technical control and the evidence; they own the call.

8. Deliverables Summary — CMMC / CUI DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The CUI DLP model — the `CUI` sensitivity label as primary signal, the marking keyword SIT as backstop, the five locations (email, SharePoint, OneDrive, Teams, endpoint), and the simulate→enforce journey; naming convention; the CMMC/assessment boundary.
Requirements Guide	Solution-specific prerequisites (CUI marking/label decision, DLP/endpoint & label-based licensing, **GCC High** tenant confirmation, CUI enclave scope, device onboarding, marking-SIT source, pilot ring, alert triage + evidence retention) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/confirm label & tenant → confirm detection layer → build policies keyed on label+marking **in simulation** → tune → enforce to a pilot ring → expand & evidence; each phase named, gated, and with a rollback.

Document	What it gives you
Testing & Validation	Pass/fail gates for the three headline outcomes — CUI leaks blocked (A), low false-positive rate (B), incidents handled & evidenced (C) — plus simulation-first and rollback checks, all with fake CUI-marked test data.
Troubleshooting Guide	The common failure modes (policy not matching CUI, marking SIT over-firing, endpoint location missing, GCC High path differences, no alerts) and how to resolve them.
Best Practices	Label-first detection, simulate-first discipline, enclave scoping, false-positive tuning, endpoint specifics, GCC High discipline, and evidence/operations.
Executive Summary	One-page business framing for approvers and contracts stakeholders.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**DLPCMMC-Discovery.ps1**	CUI DLP posture assessment: existing DLP policies and their mode, whether a `CUI` sensitivity label and CUI marking SIT are present, and licensing/endpoint/tenant readiness signals.	Read-only
2	**DLPCMMC-Config.ps1**	CUI DLP policy configuration helper: creates/updates a policy **in simulation mode** keyed on the `CUI` label (and marking SIT) and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)

#	Script	Role	Default safety
3	**DLPCMMC-Validate.ps1**	Validation-gate checker: confirms the CUI policies exist, are in the expected mode (simulation vs enforce), key off the `CUI` label/marking, and are enclave-scoped — reports pass/fail per gate.	Read-only
4	**DLPCMMC-Report.ps1**	CUI match / false-positive & evidence report: exports simulation/enforcement matches for TP-vs-FP classification, rate calculation, and the audit evidence trail.	Read-only
5	**DLPCMMC-Set-Scope.ps1**	Scope/health helper: reports and (with `-Commit`) adjusts a policy's included/excluded users/groups (the CUI enclave / pilot ring).	`-WhatIf` (writes need `-Commit`)

Definition of done

• The `CUI` **sensitivity label** is confirmed published and the **marking keyword SIT** is built from your real markings and tested.

• Email, cloud (SPO/OneDrive/Teams), and endpoint DLP policies keyed on **label = CUI** (+ marking backstop)

built and **proven in simulation**, scoped to the **CUI enclave**.

• False-positive rate measured and tuned to at/under the agreed threshold (Gate B).

• Enforcement live for the pilot ring with policy tips + override, then expanded per compliance's action determination — block/encrypt where required (Gate A).

• CUI DLP alerts raised, triaged to disposition, and the **evidence trail retained** in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and compliance sign-offs captured.

Boundary: *the solution delivers the technical control and the evidence. The* ***data that is CUI, the categories/markings in scope, the enforced action per condition, GCC High residency, DFARS incident-reporting, and all CMMC / NIST SP 800-171 control-satisfaction and assessment determinations*** *are* ***compliance / contracts / legal / C3PAO*** *decisions, captured alongside the*

delivered evidence.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPCMMC-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule) that detects CUI by the "CUI" SENSITIVITY LABEL (primary signal) and, optionally, a CUI marking keyword sensitive-information-type (backstop), across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint), in SIMULATION mode. Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step. HOW TO RUN Preview a CUI email simulation policy (label + marking backstop, external recipients): powershell -File .\DLPCMMC-Config.ps1 -PolicyName 'DLP - CUI Email - Simulation' `-Locations Exchange -SensitivityLabel 'CUI'` -MarkingSit 'CUI Banner Marking - Custom SIT - Classification' -WhatIf Actually create it (still simulation mode): powershell -File .\DLPCMMC-Config.ps1 -PolicyName 'DLP - CUI Email - Simulation' `-Locations Exchange -SensitivityLabel 'CUI'` -MarkingSit 'CUI Banner Marking - Custom SIT - Classification' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). Verify label-based DLP + Endpoint availability for your licensing/tenant (GCC High differs). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications and the label/marking condition. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPCMMC-Discovery.ps1 / DLPCMMC-Validate.ps1. .NOTES Purview — CMMC / CUI DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Primary signal: the CUI sensitivity label (leave blank only if using the marking SIT alone). [string]$SensitivityLabel = 'CUI', Backstop signal: the CUI marking keyword SIT (optional but recommended). [string]$MarkingSit, [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview a CUI email simulation policy (label + marking backstop, external recipients): powershell -File .\DLPCMMC-Config.ps1 -PolicyName 'DLP - CUI Email - Simulation' `-Locations Exchange -SensitivityLabel 'CUI'` -MarkingSit 'CUI Banner Marking - Custom SIT - Classification' -WhatIf Actually create it (still simulation mode): powershell -File .\DLPCMMC-Config.ps1 -PolicyName 'DLP - CUI Email - Simulation' `-Locations Exchange -SensitivityLabel 'CUI'` -MarkingSit 'CUI Banner Marking - Custom SIT - Classification' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). Verify label-based DLP + Endpoint availability for your licensing/tenant (GCC High differs). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications and the label/marking condition. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPCMMC-Discovery.ps1 / DLPCMMC-Validate.ps1. .NOTES Purview — CMMC / CUI DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'),

Primary signal: the CUI sensitivity label (leave blank only if using the marking SIT alone). [string]$SensitivityLabel = 'CUI', Backstop signal: the CUI marking keyword SIT (optional but recommended). [string]$MarkingSit, [int]$MinCount = 1, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

DLPCMMC-Discovery.ps1

Purpose: Builds the CUI DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers; whether a "CUI" sensitivity label is present/published; whether a CUI marking keyword sensitive-information-type exists; and licensing/endpoint/tenant readiness signals. Read-only — makes no changes. Run it before you build simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPCMMC-Discovery.ps1 -CsvPath .\DLPCMMC-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). GCC High: connect with your environment's parameters and verify the portal endpoint. EXPECTED RESULTS Console tables of DLP policies (Name, Mode, Locations), CUI sensitivity-label presence, and CUI marking-SIT presence, plus an optional CSV of the policy inventory. PASS signal: a published "CUI" label is found and the CUI DLP policies you expect are in a Test* (simulation) mode; anything already Enable that you did not intend is flagged for review. .NOTES Purview — CMMC / CUI DLP Pack. Read-only against Security & Compliance PowerShell. No changes, no credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$LabelName = 'CUI', [string]$MarkingSitName = 'CUI Banner Marking - Custom SIT - Classification', [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPCMMC-Discovery.ps1 -CsvPath .\DLPCMMC-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). GCC High: connect with your environment's parameters and verify the portal endpoint. EXPECTED RESULTS Console tables of DLP policies (Name, Mode, Locations), CUI sensitivity-label presence, and CUI marking-SIT presence, plus an optional CSV of the policy inventory. PASS signal: a published "CUI" label is found and the CUI DLP policies you expect are in a Test* (simulation) mode; anything already Enable that you did not intend is flagged for review. .NOTES Purview — CMMC / CUI DLP Pack. Read-only against Security & Compliance PowerShell. No changes, no credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$LabelName = 'CUI', [string]$MarkingSitName = 'CUI Banner Marking - Custom SIT - Classification', [string]$UserPrincipalName)

DLPCMMC-Report.ps1

Purpose: Exports CUI DLP activity from the unified audit log (DLP rule matches across Exchange, SharePoint, OneDrive, Teams, and Endpoint) so you can classify each match as true-positive vs false-positive, compute the false-positive rate during the simulation dwell, and retain an EVIDENCE trail for assessment/audit. Read-only — queries the audit log only, makes no changes. Requires unified audit logging enabled and an audit/View-Only DLP role. HOW TO RUN powershell -File .\DLPCMMC-Report.ps1 -Days 14 -CsvPath .\DLPCMMC-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession). Widen -Days if the audit log is still catching up (events can lag). EXPECTED RESULTS A console summary (match count by workload/policy) and an optional CSV with one row per DLP match (time, user, workload, policy, and available detail) for TP/FP classification and evidence retention. PASS signal: matches for your CUI simulation policies appear; add a TP/FP column

and compute the false-positive rate against the Gate B threshold. .NOTES Purview — CMMC / CUI DLP Pack. Read-only (audit-log query). No changes, no credentials in code. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$PolicyFilter = 'CUI', [string]$UserPrincipalName)

How to run: powershell -File .\DLPCMMC-Report.ps1 -Days 14 -CsvPath .\DLPCMMC-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession). Widen -Days if the audit log is still catching up (events can lag). EXPECTED RESULTS A console summary (match count by workload/policy) and an optional CSV with one row per DLP match (time, user, workload, policy, and available detail) for TP/FP classification and evidence retention. PASS signal: matches for your CUI simulation policies appear; add a TP/FP column and compute the false-positive rate against the Gate B threshold. .NOTES Purview — CMMC / CUI DLP Pack. Read-only (audit-log query). No changes, no credentials in code. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$PolicyFilter = 'CUI', [string]$UserPrincipalName)

DLPCMMC-Set-Scope.ps1

Purpose: Reports a CUI DLP policy's current location scope and, with -Commit, sets the INCLUDED / EXCLUDED users, groups, or sites so enforcement targets only the CUI enclave or the pilot ring (e.g. 'CUI DLP Pilot Ring - Stage1') rather than the whole tenant ("All"). Safe by default: with -WhatIf it only reports the intended scope change; it applies nothing unless -Commit is passed, and it will NOT flip a policy's mode (it never enforces — mode changes stay a portal/change-control step). Also prints a quick health check (mode + current scope). HOW TO RUN Report current scope only: powershell -File .\DLPCMMC-Set-Scope.ps1 -PolicyName 'DLP - CUI Email - Simulation' -WhatIf Narrow the Exchange scope to the pilot ring group (still simulation — mode untouched): powershell -File .\DLPCMMC-Set-Scope.ps1 -PolicyName 'DLP - CUI Email - Simulation' ` -Location Exchange -IncludeGroup 'CUI DLP Pilot Ring - Stage1' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current mode/scope and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the include/exclude scope and re-prints the resulting scope. Mode is never changed by this script. Verify with DLPCMMC-Validate.ps1 -ExpectScoped. .NOTES Purview — CMMC / CUI DLP Pack. Writes gated behind -Commit; never changes policy mode/enforcement. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string]$Location = 'Exchange', [string[]]$IncludeGroup, [string[]]$ExcludeGroup, [string]$UserPrincipalName, [switch]$Commit)

How to run: Report current scope only: powershell -File .\DLPCMMC-Set-Scope.ps1 -PolicyName 'DLP - CUI Email - Simulation' -WhatIf Narrow the Exchange scope to the pilot ring group (still simulation — mode untouched): powershell -File .\DLPCMMC-Set-Scope.ps1 -PolicyName 'DLP - CUI Email - Simulation' ` -Location Exchange -IncludeGroup 'CUI DLP Pilot Ring - Stage1' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current mode/scope and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the include/exclude scope and re-prints the resulting scope. Mode is never changed by this script. Verify with DLPCMMC-Validate.ps1 -ExpectScoped. .NOTES Purview — CMMC / CUI DLP Pack. Writes gated behind -Commit; never changes policy mode/enforcement. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string]$Location = 'Exchange', [string[]]$IncludeGroup, [string[]]$ExcludeGroup, [string]$UserPrincipalName, [switch]$Commit)

DLPCMMC-Validate.ps1

Purpose: Checks the CUI DLP policies against the solution's validation gates: that each named policy EXISTS, is in the EXPECTED mode (simulation during build/pilot vs enforce after expand), keys off the CUI SENSITIVITY LABEL and/or the CUI marking SIT in its rule, and is scoped (not left at "All" once a pilot ring/enclave is expected). Read-only — reports PASS/FAIL per gate, changes nothing. Use it after DLPCMMC-Config.ps1 and before/after moving to enforcement. HOW TO RUN Validate the three simulation policies expect a Test* mode: powershell -File .\DLPCMMC-Validate.ps1 -PolicyNames 'DLP - CUI Email - Simulation','DLP - CUI SPO+OneDrive+Teams - Simulation','DLP - CUI Endpoint - Simulation' -ExpectMode Simulation Validate the enforced pilot policy is scoped and enforcing: powershell -File .\DLPCMMC-Validate.ps1 -PolicyNames 'DLP - CUI All Locations - Enforce Pilot' -ExpectMode Enforce -ExpectScoped Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table for: exists, mode matches -ExpectMode, references the CUI label or marking SIT, and (with -ExpectScoped) is not scoped to "All". Overall PASS only if every checked gate passes. .NOTES Purview — CMMC / CUI DLP Pack. Read-only. Reports gate status only; makes no changes; no credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string[]]$PolicyNames, [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', [string]$SensitivityLabel = 'CUI', [string]$MarkingSit = 'CUI Banner Marking - Custom SIT - Classification', [switch]$ExpectScoped, [string]$UserPrincipalName)

How to run: Validate the three simulation policies expect a Test* mode: powershell -File .\DLPCMMC-Validate.ps1 -PolicyNames 'DLP - CUI Email - Simulation','DLP - CUI SPO+OneDrive+Teams - Simulation','DLP - CUI Endpoint - Simulation' -ExpectMode Simulation Validate the enforced pilot policy is scoped and enforcing: powershell -File .\DLPCMMC-Validate.ps1 -PolicyNames 'DLP - CUI All Locations - Enforce Pilot' -ExpectMode Enforce -ExpectScoped Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table for: exists, mode matches -ExpectMode, references the CUI label or marking SIT, and (with -ExpectScoped) is not scoped to "All". Overall PASS only if every checked gate passes. .NOTES Purview — CMMC / CUI DLP Pack. Read-only. Reports gate status only; makes no changes; no credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string[]]$PolicyNames, [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', [string]$SensitivityLabel = 'CUI', [string]$MarkingSit = 'CUI Banner Marking - Custom SIT - Classification', [switch]$ExpectScoped, [string]$UserPrincipalName)